Experiment 11

AIM: Use OWASP ZAP to check security integrity.

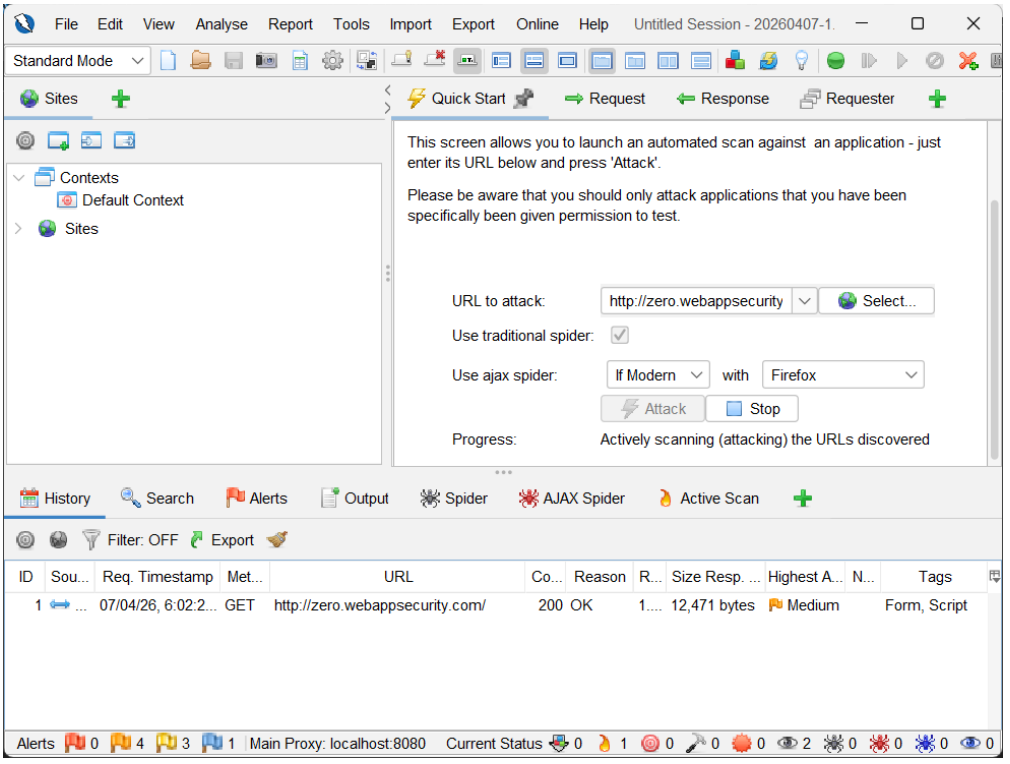
1. Install ZAP
   Download OWASP ZAP
   Install and open

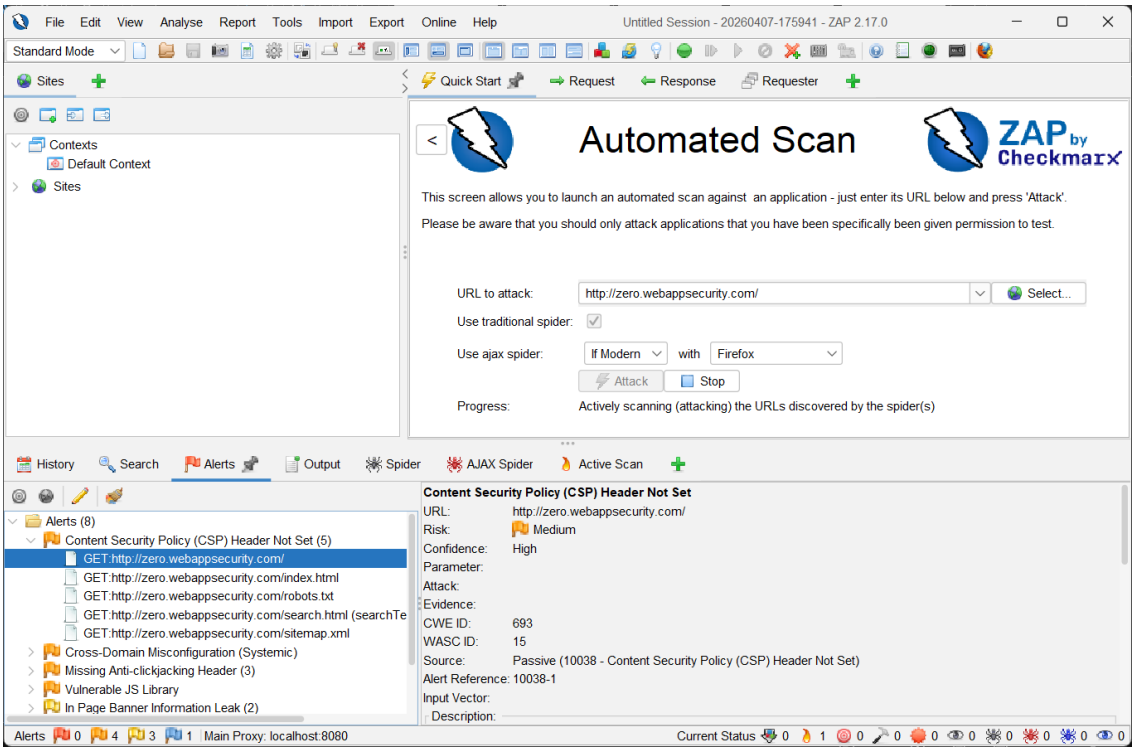
2. Quick Start
   You'll see: "Quick Start" screen
   Click:
   Automated Scan

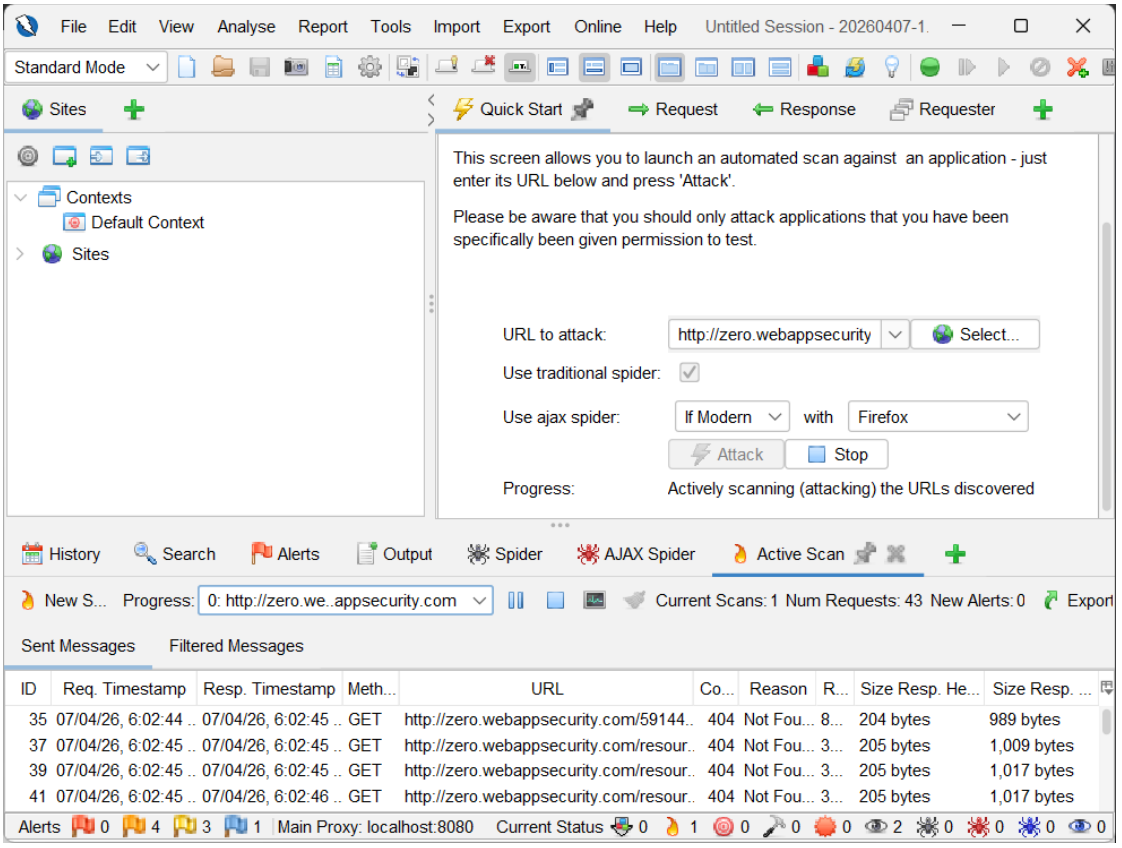
3. Enter Target URL
   Use safe demo site:
   http://zero.webappsecurity.com/

4. Start Scan
   Click:
   Attack

5. Verify Results
   Alerts
   Risk levels:
   High
   Medium
   Low




File Edit View Analyse Report Tools Import Export Online Help
Untitled Session - 20260407-175941 - ZAP 2.17.0
Standard Mode
Sites
Quick Start
Request
Response
Requester
Contexts
Default Context
Sites
Automated Scan
ZAP by Checkmarx
This screen allows you to launch an automated scan against an application - just enter its URL below and press 'Attack'.
Please be aware that you should only attack applications that you have been specifically been given permission to test.
URL to attack:
http://zero.webappsecurity.com/
Select...
Use traditional spider:
Use ajax spider:
If Modern
with
Firefox
Attack
Stop
Progress:
Actively scanning (attacking) the URLs discovered by the spider(s)
History
Search
Alerts
Output
Spider
AJAX Spider
Active Scan
Alerts (8)
Content Security Policy (CSP) Header Not Set (5)
GET:http://zero.webappsecurity.com/
GET:http://zero.webappsecurity.com/index.html
GET:http://zero.webappsecurity.com/robots.txt
GET:http://zero.webappsecurity.com/search.html (searchTe
GET:http://zero.webappsecurity.com/sitemap.xml
Cross-Domain Misconfiguration (Systemic)
Missing Anti-clickjacking Header (3)
Vulnerable JS Library
In Page Banner Information Leak (2)
Content Security Policy (CSP) Header Not Set
URL: http://zero.webappsecurity.com/
Risk: Medium
Confidence: High
Parameter:
Attack:
Evidence:
CWE ID: 693
WASC ID: 15
Source: Passive (10038 - Content Security Policy (CSP) Header Not Set)
Alert Reference: 10038-1
Input Vector:
Description:
Alerts 0 4 3 1 Main Proxy: localhost:8080
Current Status


File Edit View Analyse Report Tools Import Export Online Help
Untitled Session - 20260407-1
Standard Mode
Sites
Quick Start
Request
Response
Requester
Contexts
Default Context
Sites
This screen allows you to launch an automated scan against an application - just enter its URL below and press 'Attack'.
Please be aware that you should only attack applications that you have been specifically been given permission to test.
URL to attack:
http://zero.webappsecurity
Select...
Use traditional spider:
Use ajax spider:
If Modern
with
Firefox
Attack
Stop
Progress:
Actively scanning (attacking) the URLs discovered
History
Search
Alerts
Output
Spider
AJAX Spider
Active Scan
New S...
Progress:
0: http://zero.we..appsecurity.com
Current Scans: 1 Num Requests: 43 New Alerts: 0
Export
Sent Messages
Filtered Messages
ID Req. Timestamp Resp. Timestamp Meth... URL Co... Reason R... Size Resp. He... Size Resp. ...
35 07/04/26, 6:02:44 .. 07/04/26, 6:02:45 .. GET http://zero.webappsecurity.com/59144.. 404 Not Fou... 8... 204 bytes 989 bytes
37 07/04/26, 6:02:45 .. 07/04/26, 6:02:45 .. GET http://zero.webappsecurity.com/resour.. 404 Not Fou... 3... 205 bytes 1,009 bytes
39 07/04/26, 6:02:45 .. 07/04/26, 6:02:45 .. GET http://zero.webappsecurity.com/resour.. 404 Not Fou... 3... 205 bytes 1,017 bytes
41 07/04/26, 6:02:45 .. 07/04/26, 6:02:46 .. GET http://zero.webappsecurity.com/resour.. 404 Not Fou... 3... 205 bytes 1,017 bytes
Alerts 0 4 3 1 Main Proxy: localhost:8080 Current Status